Manual · Usar la VulnBank API endurecida con `curl` desde tu Mac

> Guía para **usar la API correctamente** cuando está puesta la versión **ENDURECIDA**: iniciar sesión, consultar tu cuenta, transferir, administrar… y ver cómo responde a los ataques. Todo se hace desde la app **Terminal** del Mac, copiando y pegando. Los datos son **ficticios**.

1. Antes de empezar

1. Abre **Terminal** (Cmd + Espacio, escribe `Terminal`, Enter).
2. `curl` ya viene instalado en macOS. Compruébalo:

```
curl --version
```

1. Comprueba que la API publicada es la **endurecida**:

```
curl -s https://yellow-ground-024d78310.6.azurestaticapps.net/api/lab/version
```

Debes ver:

```
{
  "lab": "VulnBank API",
  "version": "endurecida"
}
```

> Si dice `"vulnerable"`, pídele a Claude: **"Coloca el laboratorio de API endurecida"** y espera 2–3 minutos.

3 reglas que debes recordar

Regla	Por qué
Pon **siempre las URL entre comillas** `"…"`	La Terminal del Mac (zsh) interpreta `?` y da `no matches found`.
El token va en la cabecera `X-Auth-Token`	Azure reserva `Authorization` para su propio login.
El token **caduca a los 15 minutos**	Si recibes `401`, vuelve a iniciar sesión (paso 3).

2. Guarda la dirección de la API (una vez por ventana)

```
B="https://yellow-ground-024d78310.6.azurestaticapps.net/api/lab"
```

Esta variable dura mientras tengas abierta esa ventana de Terminal. Si abres otra ventana, vuelve a pegarla.

Para empezar con los datos limpios (saldos y perfiles iniciales):

```
curl -s -X POST "$B/reset"
```

3. Iniciar sesión y guardar el token

Usuarios de prueba:

Usuario	Contraseña	Cuenta	Rol
`laura`	`Laura2026!`	5001	cliente
`carlos`	`123456`	5002	cliente
`admin`	`Adm1n!VulnB4nk#2026`	5003	administrador

> Estas contraseñas son para ti como instructor. En la práctica vulnerable, las de `carlos` y `admin` son parte del reto: no se las des a los alumnos.

Iniciar sesión como Laura y guardar su token en la variable `TOKEN`:

```
TOKEN=$(curl -s -X POST "$B/auth/login" \
  -H "Content-Type: application/json" \
  -d '{"username":"laura","password":"Laura2026!"}' \
  | sed -nE 's/.*"token": "([^"]+)".*/\1/p')
echo "$TOKEN"
```

Debes ver una línea larga que empieza por `eyJ…` (es un JWT). Si sale vacía, revisa el usuario y la contraseña.

Ver la respuesta completa del login (opcional):

```
curl -s -X POST "$B/auth/login" -H "Content-Type: application/json" \
  -d '{"username":"laura","password":"Laura2026!"}'
```

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9…",
  "expiresIn": 900,
  "user": { "id": 1001, "username": "laura", "fullName": "Laura Gómez", "email": "laura@vu
lnbank.example", "phone": "+34 600 111 222", "role": "customer", "accountId": 5001 }
}
```


`expiresIn: 900` = el token vale 900 segundos (15 minutos).

4. Usar la API como Laura (cliente)

4.1 Ver mi perfil

```
curl -s "$B/users/me" -H "X-Auth-Token: $TOKEN"
```

Solo devuelve datos públicos: `id, username, fullName, email, phone, role, accountId`. Nada de contraseñas, DNI ni PIN.

4.2 Cambiar mi email o teléfono

```
curl -s -X PATCH "$B/users/me" -H "X-Auth-Token: $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"email":"laura.nueva@vulnbank.example","phone":"+34 611 222 333"}'
```

Solo se pueden cambiar **`email`** y **`phone`**, y deben tener un formato válido.

4.3 Ver mi cuenta y saldo

```
curl -s "$B/accounts/5001" -H "X-Auth-Token: $TOKEN"
```


```
{ "id": 5001, "ownerId": 1001, "iban": "ES00 0000 0000 0000 0000 5001", "balance": 2450.7
5, "currency": "EUR", "ownerName": "Laura Gómez" }
```


4.4 Ver mis movimientos

```
curl -s "$B/accounts/5001/transactions?limit=5" -H "X-Auth-Token: $TOKEN"
```

`limit` acepta de **1 a 50**. Sin `limit` devuelve 20.

4.5 Hacer una transferencia

```
curl -s -X POST "$B/transfers" -H "X-Auth-Token: $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"fromAccountId":5001,"toAccountId":5002,"amount":25.50}'
```

```
{ "ok": true, "from": { "id": 5001, "balance": 2425.25 }, "to": { "id": 5002 } }
```

Reglas que aplica la API endurecida:

- `fromAccountId` tiene que ser **tu** cuenta.
- `toAccountId` tiene que existir y ser distinta de la de origen.
- `amount` tiene que ser un **número** (sin comillas), **positivo**, con **2 decimales como máximo**, **≤ 10000** y **≤ tu saldo**.
- La respuesta **no** muestra el saldo de la cuenta destino (no es tuyo).

4.6 Vista previa de un enlace

Solo admite enlaces `https` de los dominios del banco:

```
curl -s "$B/tools/preview?url=https://cdn.vulnbank.example/logo.png" -H "X-Auth-Token: $TO
KEN"
```

Dominios permitidos: `cdn.vulnbank.example` y `www.vulnbank.example`.

5. Usar la API como administrador

```
ADMIN=$(curl -s -X POST "$B/auth/login" \
  -H "Content-Type: application/json" \
  -d '{"username":"admin","password":"Adm1n!VulnB4nk#2026"}' \
  | sed -nE 's/.*"token": "([^"]+)".*/\1/p')

curl -s "$B/admin/users" -H "X-Auth-Token: $ADMIN"
```

El admin ve la lista de usuarios **sin datos sensibles**. Si lo intenta Laura:

```
curl -s "$B/admin/users" -H "X-Auth-Token: $TOKEN"
```

```
{ "error": "Acceso denegado" }
```

6. Ver el código HTTP de cada respuesta

Añade `-i` para ver la línea de estado y las cabeceras:

```
curl -s -i "$B/accounts/5001" -H "X-Auth-Token: $TOKEN"
```

O solo el código, al final de la respuesta:

```
curl -s -w '\nHTTP %{http_code}\n' "$B/accounts/5001" -H "X-Auth-Token: $TOKEN"
```

Qué significa cada respuesta

Código	Mensaje típico	Qué hacer
`200`	(datos)	Todo bien.
`400`	`amount debe ser…`, `Campos no permitidos…`, `limit debe estar entre 1 y 50`	Corrige los datos que envías.
`401`	`Credenciales inválidas`	Usuario o contraseña incorrectos.
`401`	`Falta un token válido (cabecera X-Auth-Token)`	Token ausente, mal copiado o caducado: repite el paso 3.
`403`	`Acceso denegado`	Tu rol no tiene permiso (solo admin).
`404`	`Cuenta no encontrada`	La cuenta no existe **o no es tuya**.
`410`	`La API v1 está retirada`	Usa `/api/lab/…` (sin `v1`).
`429`	`Demasiados intentos. Espera 15 minutos.`	5 logins fallidos: espera o ejecuta `curl -s -X POST "$B/reset"`.
`500`	`Error interno` + `requestId`	Error del servidor; no muestra detalles internos.

7. Demostración: los ataques ya no funcionan

Con `TOKEN` de Laura cargado, pega cada línea y compara con la tabla.

#	Ataque	Comando	Respuesta endurecida
V1	Leer la cuenta de Carlos	`curl -s "$B/accounts/5002" -H "X-Auth-Token: $TOKEN"`	`404 Cuenta no encontrada`
V2	Token sin firma (`alg: none`)	`curl -s "$B/users/me" -H "X-Auth-Token: eyJhbGciOiJub25lIiwidHlwIjoiSldUIn0.eyJzdWIiOjEwMDN9."`	`401`
V4	Datos sensibles en el perfil	`curl -s "$B/users/me" -H "X-Auth-Token: $TOKEN"`	Sin `password` , `dni` , `pin`
V5	Ponerse admin	`curl -s -X PATCH "$B/users/me" -H "X-Auth-Token: $TOKEN" -H "Content-Type: application/json" -d '{"role":"admin"}'`	`400 Campos no permitidos: role`
V6	Panel de admin siendo cliente	`curl -s "$B/admin/users" -H "X-Auth-Token: $TOKEN"`	`403 Acceso denegado`
V7	Transferencia negativa	`curl -s -X POST "$B/transfers" -H "X-Auth-Token: $TOKEN" -H "Content-Type: application/json" -d '{"fromAccountId":5001,"toAccountId":5002,"amount":-1000}'`	`400 amount debe ser un número positivo…`
V8	SSRF a metadatos	`curl -s "$B/tools/preview?url=http://169.254.169.254/latest/meta-data/" -H "X-Auth-Token: $TOKEN"`	`400 Destino no permitido`
V9	Endpoint de depuración	`curl -s "$B/debug" -H "X-Auth-Token: $TOKEN"`	`404 Ruta no encontrada`
V9	CORS desde otra web	`curl -s -i "$B/version" -H "Origin: https://evil.example" | grep -i access-control`	No aparece nada
V10	API antigua	`curl -s "$B/v1/users/1002"`	`410 La API v1 está retirada`
V11	Inyección NoSQL	`curl -s -X POST "$B/auth/login" -H "Content-Type: application/json" -d '{"username":"admin","password":{"$ne":""}}'`	`400 username y password deben ser texto`
V12	Pedir 20 000 registros	`curl -s "$B/accounts/5001/transactions?limit=20000" -H "X-Auth-Token: $TOKEN"`	`400 limit debe estar entre 1 y 50`

V3 · Fuerza bruta (bloqueo al 5.º intento):

```
for p in uno dos tres cuatro cinco seis; do
  curl -s -o /dev/null -w "$p → HTTP %{http_code}\n" -X POST "$B/auth/login" \
    -H "Content-Type: application/json" -d "{\"username\":\"carlos\",\"password\":\"$p\"}"
done
```

Verás `401` cinco veces y después `429`. Desbloquea con `curl -s -X POST "$B/reset"` y vuelve a iniciar sesión (paso 3).

8. Todo de una vez (script para copiar y pegar)

Pega el bloque completo en la Terminal. Hace el recorrido entero y muestra cada resultado con su código HTTP:

```
B="https://yellow-ground-024d78310.6.azurestaticapps.net/api/lab"
paso() { printf '\n\033[1;32m== %s\033[0m\n' "$1"; }
curl -s -X POST "$B/reset" >/dev/null

paso "Versión"
curl -s "$B/version"

paso "Login como laura"
TOKEN=$(curl -s -X POST "$B/auth/login" -H "Content-Type: application/json" \
  -d '{"username":"laura","password":"Laura2026!"}' | sed -nE 's/.*"token": "([^"]+)".*/
\1/p')
[ -n "$TOKEN" ] && echo "Token OK" || echo "ERROR: no hay token"

paso "Mi perfil"
curl -s -w '\nHTTP %{http_code}\n' "$B/users/me" -H "X-Auth-Token: $TOKEN"

paso "Mi cuenta"
curl -s -w '\nHTTP %{http_code}\n' "$B/accounts/5001" -H "X-Auth-Token: $TOKEN"

paso "Transferir 25.50 a Carlos"
curl -s -w '\nHTTP %{http_code}\n' -X POST "$B/transfers" -H "X-Auth-Token: $TOKEN" \
  -H "Content-Type: application/json" -d '{"fromAccountId":5001,"toAccountId":5002,"amoun
t":25.50}'

paso "ATAQUE: leer la cuenta de Carlos (debe dar 404)"
curl -s -w '\nHTTP %{http_code}\n' "$B/accounts/5002" -H "X-Auth-Token: $TOKEN"

paso "ATAQUE: transferencia negativa (debe dar 400)"
curl -s -w '\nHTTP %{http_code}\n' -X POST "$B/transfers" -H "X-Auth-Token: $TOKEN" \
  -H "Content-Type: application/json" -d '{"fromAccountId":5001,"toAccountId":5002,"amoun
t":-1000}'

paso "ATAQUE: panel de admin siendo cliente (debe dar 403)"
curl -s -w '\nHTTP %{http_code}\n' "$B/admin/users" -H "X-Auth-Token: $TOKEN"

paso "Restaurar datos"
curl -s -X POST "$B/reset"
```

9. Problemas frecuentes en Mac

Síntoma	Solución
`zsh: no matches found: …?limit=5`	Pon la URL entre comillas dobles: `"$B/…?limit=5"`.
`zsh: event not found`	Usa comillas **simples** `'…'` en el `-d` cuando haya `!` (como en `Laura2026!`).
`echo "$TOKEN"` sale vacío	El login falló: ejecuta el login sin el `sed` (paso 3, opcional) y lee el error.
`401 Falta un token válido`	Token caducado (15 min) o variable perdida al abrir otra ventana: repite pasos 2 y 3.
`429 Demasiados intentos`	`curl -s -X POST "$B/reset"` y vuelve a iniciar sesión.
La respuesta sale en una sola línea larga	Añade al final `| python3 -m json.tool` (o instala `jq` con `brew install jq` y usa `| jq`).
`curl: (6) Could not resolve host`	Revisa la conexión a Internet y que la variable `B` esté bien escrita.